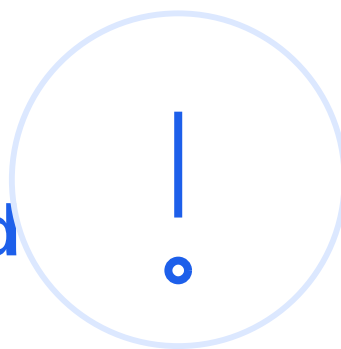
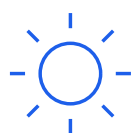


Protocolo de Incidentes Técnicos y de Seguridad



Guía corporativa para reportar, contener y resolver incidentes



Sol AI
INTELIGENCIA QUE ILUMINA DECISIONES

Contenido

- Objetivo, alcance y definiciones
- Tipos de incidentes y severidad
- Tiempos y canales de reporte
- Acciones iniciales y acciones prohibidas
- Clasificación, escalamiento y respuesta
- Contención, investigación y recuperación
- Comunicación y cierre
- Post-mortem, roles e indicadores
- Ejemplos y preguntas frecuentes

Versión 1.0 · Julio de 2026

1. Objetivo del protocolo

Definir una respuesta coordinada, rápida y documentada ante incidentes técnicos, operativos o de seguridad que puedan afectar sistemas, datos, colaboradores, clientes o la continuidad de NexoData Consulting.

Regla principal

Ante la duda, reporta. Es preferible investigar un evento que no resulte grave que ignorar una señal que pueda crecer.

2. Alcance

- Aplica a colaboradores, contratistas, proveedores y terceros con acceso a recursos de NexoData.
- Cubre infraestructura, aplicaciones, bases, cuentas, dispositivos, repositorios, documentos y servicios en la nube.
- Incluye eventos de seguridad, disponibilidad, calidad, integridad de datos y uso inadecuado de herramientas.
- Aplica tanto a entornos internos como a proyectos y servicios de clientes.

3. Qué se considera un incidente

Un incidente es cualquier evento que afecte o pueda afectar la confidencialidad, integridad, disponibilidad, trazabilidad o funcionamiento esperado de un activo, servicio o proceso.

- Acceso no autorizado o sospechoso.
- Pérdida, robo o uso indebido de equipos.
- Exposición, modificación o eliminación no autorizada de datos.
- Interrupción o degradación de servicios.
- Errores graves en aplicaciones, modelos, automatizaciones o dashboards.
- Phishing, malware, ransomware o intento de fraude.
- Divulgación accidental de información.
- Uso de herramientas no aprobadas con información interna.
- Fallo de respaldos o imposibilidad de recuperación.
- Resultados de IA que generen riesgo operativo o reputacional.

4. Tipos de incidentes

- Seguridad de la información.
- Infraestructura y disponibilidad.
- Aplicaciones y software.
- Datos y bases.
- Identidades y accesos.
- Servicios en la nube.

- Proveedores e integraciones.
- Calidad de entregables.
- Inteligencia artificial y modelos.
- Continuidad operativa.

5. Niveles de severidad

Severidad	Criterio	Ejemplos	Respuesta inicial
SEV-1 Crítica	Interrupción total, exposición relevante, riesgo legal o afectación a múltiples clientes.	Filtración confirmada, ataque activo, pérdida de sistema crítico.	Activar respuesta inmediata, liderazgo ejecutivo y comunicación controlada.
SEV-2 Alta	Impacto importante, degradación severa o riesgo alto de exposición.	Acceso no autorizado limitado, servicio principal degradado.	Escalar en minutos, contener y definir plan de recuperación.
SEV-3 Media	Impacto parcial o controlado sin evidencia de exposición grave.	Error de integración, caída de módulo no crítico.	Registrar, asignar responsable y resolver dentro del mismo día.
SEV-4 Baja	Impacto menor, sin afectación significativa a datos o usuarios.	Error visual, solicitud técnica menor.	Gestionar mediante soporte ordinario.

Clasificación dinámica

La severidad puede aumentar o disminuir conforme se obtiene nueva información. Todo cambio debe quedar registrado.

6. Tiempos máximos de reporte

Tipo	Reporte máximo	Acuse esperado	Actualización
SEV-1	Inmediato	15 minutos	Cada 30 minutos
SEV-2	Máximo 15 minutos	30 minutos	Cada 60 minutos
SEV-3	Dentro de 1 hora	4 horas hábiles	Según plan
SEV-4	Misma jornada	1 día hábil	Al resolver

7. Canales oficiales de notificación

Situación	Canal principal	Canal alternativo	Responsable receptor
Seguridad crítica	#seguridad / teléfono de emergencia	Correo de incidentes	Seguridad de la Información
Servicio o infraestructura	#soporte / #cloud	Mesa de Soporte	Tecnología e Infraestructura
Datos o base	#datos	Mesa de Soporte	Ingeniería de Datos / DBA
Aplicación o código	#dev	Issue privado del proyecto	Líder Técnico
Cliente afectado	Project Manager	Dirección de Proyectos	Gestión de Proyectos

8. Información mínima del reporte

Campo	Descripción
Fecha y hora	Cuándo se detectó y, si se conoce, cuándo comenzó.
Persona que reporta	Nombre, área y canal de contacto.
Sistema o activo	Equipo, aplicación, repositorio, cuenta o servicio afectado.
Descripción	Qué ocurrió, qué se observó y cómo se detectó.
Impacto	Usuarios, datos, procesos o clientes afectados.
Evidencia	Capturas, logs, mensajes, correos o indicadores disponibles.
Acciones realizadas	Pasos ejecutados antes del reporte.
Estado actual	Activo, contenido, recuperado o desconocido.

9. Acciones iniciales del colaborador

- Mantener la calma y priorizar la seguridad de las personas.
- Reportar por el canal adecuado sin esperar a conocer todos los detalles.
- Preservar correos, capturas, logs, archivos y mensajes relevantes.
- Desconectar el equipo de la red solo cuando exista riesgo de propagación o se indique hacerlo.
- Registrar la hora, el sistema afectado y cualquier cambio reciente.
- Seguir las instrucciones del equipo responsable.
- Mantener la información del incidente limitada a quienes participan en la respuesta.

10. Acciones que no deben realizarse

- No borrar archivos, correos o registros sin autorización.
- No reiniciar repetidamente un sistema si puede perderse evidencia.
- No contactar al cliente, proveedor o medios por cuenta propia.
- No compartir capturas o detalles en canales generales.
- No culpar públicamente a personas o equipos.
- No ejecutar herramientas forenses o de recuperación sin autorización.
- No ocultar errores por temor a consecuencias.
- No modificar credenciales de terceros ni intentar investigar fuera del alcance asignado.

11. Proceso de clasificación

- Registrar el evento en el sistema de incidentes.
- Confirmar activo, impacto, usuarios y datos potencialmente afectados.
- Asignar categoría y severidad preliminar.
- Nombrar una persona responsable o Incident Manager.
- Definir equipo de respuesta.
- Establecer frecuencia de actualización.
- Reclasificar cuando aparezca nueva evidencia.

12. Escalamiento

Condición	Escalamiento mínimo
Posible exposición de datos personales	Seguridad + Dirección + Asesoría legal o responsable de privacidad.
Cliente afectado	Project Manager + Dirección de Proyectos + Seguridad.
Interrupción de servicio crítico	Infraestructura + Líder Técnico + Dirección.
Credenciales comprometidas	Seguridad + Soporte + propietario del sistema.
Impacto financiero o contractual	Dirección + Administración y Finanzas + Project Manager.
Cobertura mediática o comunicación externa	Dirección General + Comunicación autorizada.

13. Investigación y contención

- Delimitar el alcance real y potencial.
- Revisar logs, alertas, accesos, cambios y dependencias.
- Aislar cuentas, equipos, servicios o integraciones cuando sea necesario.
- Revocar o rotar credenciales comprometidas.
- Conservar evidencia de manera íntegra y trazable.
- Documentar cada acción con hora, responsable y resultado.
- Evitar cambios que dificulten determinar la causa.

14. Recuperación del servicio

- Eliminar o mitigar la causa inmediata.
- Restaurar desde respaldos verificados cuando corresponda.
- Realizar pruebas antes de reactivar el servicio.
- Aumentar monitoreo durante el periodo de estabilización.
- Confirmar integridad de datos y funcionamiento.
- Informar a usuarios y responsables sobre el estado.
- Mantener un plan de reversión si la solución falla.

15. Comunicación con clientes

Audiencia	Quién comunica	Contenido permitido
Equipo interno	Incident Manager o responsable designado	Estado, impacto, acciones y próximos pasos.
Cliente	Project Manager o persona autorizada	Hechos confirmados, impacto, mitigación y siguiente actualización.
Proveedores	Responsable contractual o técnico	Acciones requeridas y plazo.
Público o medios	Dirección o vocería autorizada	Únicamente comunicación aprobada.

- Comunicar únicamente hechos confirmados.
- No especular sobre causas, responsables o alcance.
- Indicar acciones de mitigación y próxima actualización.
- Registrar la aprobación de mensajes externos.
- Mantener consistencia entre los canales.

16. Cierre del incidente

- Confirmar que el servicio o activo esté estable.
- Verificar que las credenciales y accesos sean seguros.
- Cerrar tareas de contención y recuperación.
- Documentar impacto, causa preliminar y tiempos.
- Registrar pendientes con responsable y fecha.
- Obtener aprobación del Incident Manager.
- Notificar el cierre a las partes correspondientes.

17. Post-mortem y lecciones aprendidas

Los incidentes SEV-1 y SEV-2 requieren post-mortem. Los SEV-3 pueden requerirlo cuando exista recurrencia, impacto relevante o una oportunidad clara de mejora.

- Construir una línea de tiempo basada en hechos.
- Identificar causa raíz y factores contribuyentes.
- Evitar un enfoque punitivo; analizar procesos, controles y condiciones.
- Definir acciones preventivas, responsables y fechas.
- Compartir aprendizajes con las áreas pertinentes.
- Verificar posteriormente el cierre de las acciones.

18. Roles y responsabilidades

Rol	Responsabilidad principal
Colaborador que detecta	Reportar de inmediato, preservar evidencia y seguir instrucciones.
Mesa de Soporte	Registrar, clasificar preliminarmente y canalizar.
Seguridad de la Información	Liderar incidentes de seguridad, coordinar contención e investigación.
Tecnología e Infraestructura	Restaurar servicios, analizar sistemas y ejecutar cambios técnicos.
Líder Técnico	Evaluar impacto técnico y coordinar solución en aplicaciones.
Ingeniería de Datos / DBA	Proteger integridad, disponibilidad y recuperación de datos.
Project Manager	Coordinar impacto en proyecto, cliente, cronograma y comunicación.
Calidad	Verificar evidencias, acciones correctivas y cierre.
Dirección General	Tomar decisiones ejecutivas y autorizar comunicaciones externas.

19. Indicadores de gestión

Indicador	Definición
MTTA	Tiempo promedio desde detección hasta reconocimiento.
MTTR	Tiempo promedio desde detección hasta recuperación.
Tiempo de reporte	Minutos entre detección y notificación.
Incidentes por severidad	Cantidad de casos por nivel.
Reincidencia	Incidentes repetidos por causa conocida.
Cumplimiento de post-mortem	Porcentaje de incidentes que completan revisión.
Acciones vencidas	Medidas correctivas no cerradas en la fecha acordada.
Disponibilidad recuperada	Tiempo y porcentaje de recuperación del servicio.

20. Ejemplos de incidentes

Pérdida de computadora

Reportar de inmediato, indicar lugar y hora, no intentar acceder desde terceros y seguir el procedimiento de bloqueo remoto.

Correo de phishing

No abrir enlaces, no responder, conservar el mensaje y reportarlo al canal de seguridad.

Archivo enviado al destinatario equivocado

Reportar sin demora, no ocultarlo y seguir instrucciones para revocar acceso o solicitar eliminación.

Servicio web caído

Registrar hora, alcance, síntomas, cambios recientes y evidencia de monitoreo.

API key expuesta en GitHub

Revocar la clave, retirar el secreto del historial cuando corresponda, revisar accesos y reportar.

Datos alterados

Evitar nuevas modificaciones, preservar logs y solicitar validación al área de datos.

Respuesta incorrecta de IA

Registrar pregunta, contexto, respuesta, versión del modelo y efecto generado; evaluar si existe riesgo para usuarios.

21. Preguntas frecuentes

¿Puedo borrar un archivo comprometido?

No antes de recibir instrucciones. Podrías eliminar evidencia importante. Primero reporta y preserva la información disponible.

¿Quién contacta al cliente?

El Project Manager o una persona expresamente autorizada. Los colaboradores no deben comunicarse directamente sobre el incidente sin coordinación.

¿Qué hago si no sé la severidad?

Reporta con toda la información disponible. Soporte o Seguridad realizará la clasificación inicial.

¿Debo reportar aunque el problema ya se resolvió?

Sí. El registro permite evaluar impacto, identificar causas y prevenir recurrencias.

¿Puedo comentar el incidente en un chat general?

No. Utiliza únicamente los canales definidos y comparte información solo con quienes participan en la respuesta.

¿Qué ocurre después del cierre?

Los incidentes relevantes pasan por post-mortem, acciones correctivas y seguimiento.

Sol AI te acompaña

Puedes preguntarle qué hacer ante un evento, cómo reportarlo, qué información incluir, quién debe escalarlo y qué acciones evitar. Sol AI responderá utilizando este protocolo y mencionará el documento de manera natural.